



Sky: LZ Gov Bridge Support Xchain - Helpers

Security Review

Cantina Managed review by:

Christoph Michel, Lead Security Researcher

Xmxanuel, Lead Security Researcher

May 12, 2026

Contents

1	Introduction	2
1.1	About Cantina	2
1.2	Disclaimer	2
1.3	Risk assessment	2
1.3.1	Severity Classification	2
2	Security Review Summary	3
3	Findings	4
3.1	Informational	4
3.1.1	LZ receiver gas/value assumptions	4
3.1.2	Calling <code>LZComposeReceiver.lzReceive</code> with <code>msg.value</code> results in locked native tokens	4

1 Introduction

1.1 About Cantina

Cantina is a security services marketplace that connects top security researchers and solutions with clients. Learn more at cantina.xyz

1.2 Disclaimer

Cantina Managed provides a detailed evaluation of the security posture of the code at a particular moment based on the information available at the time of the review. While Cantina Managed endeavors to identify and disclose all potential security issues, it cannot guarantee that every vulnerability will be detected or that the code will be entirely secure against all possible attacks. The assessment is conducted based on the specific commit and version of the code provided. Any subsequent modifications to the code may introduce new vulnerabilities that were absent during the initial review. Therefore, any changes made to the code require a new security review to ensure that the code remains secure. Please be advised that the Cantina Managed security review is not a replacement for continuous security measures such as penetration testing, vulnerability scanning, and regular code reviews.

1.3 Risk assessment

Severity level	Impact: High	Impact: Medium	Impact: Low
Likelihood: high	Critical	High	Medium
Likelihood: medium	High	Medium	Low
Likelihood: low	Medium	Low	Low

1.3.1 Severity Classification

The severity of security issues found during the security review is categorized based on the above table. Critical findings have a high likelihood of being exploited and must be addressed immediately. High findings are almost certain to occur, easy to perform, or not easy but highly incentivized thus must be fixed as soon as possible.

Medium findings are conditionally possible or incentivized but are still relatively likely to occur and should be addressed. Low findings are a rare combination of circumstances to exploit, or offer little to no incentive to exploit but are recommended to be addressed.

Lastly, some findings might represent objective improvements that should be addressed but do not impact the project's overall security (Gas and Informational findings).

2 Security Review Summary

Sky Protocol is a decentralised protocol developed around the USDS stablecoin.

From Apr 6th to Apr 26th the Cantina team conducted a review of [xchain-helpers](#) on commit hash [d1e9c3d9](#). The team identified a total of **2** issues:

Issues Found

Severity	Count	Fixed	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	0	0	0
Low Risk	0	0	0
Gas Optimizations	0	0	0
Informational	2	0	2
Total	2	0	2

The Cantina Managed team reviewed Sky's [xchain-helpers](#) holistically on commit hash [651ff48b](#) and concluded that all findings were addressed and no new vulnerabilities were identified.

3 Findings

3.1 Informational

3.1.1 LZ receiver gas/value assumptions

Severity: Informational

Context: `LZComposeReceiver.sol#L62`

Description: For the LZ receivers (`LZComposeReceiver` and `LZReceiver`), `EndpointV2.lzReceive` is permissionless, so the source-chain (compose or receive) execution options for gas and `msg.value` cannot be assumed to hold when this path is invoked.

An attacker can call into the receive flow with arbitrary gas and value, meaning any logic that depends on forwarded `msg.value` must be validated in the `target` contract itself.

Additionally, target invocations must not appear successful when provided insufficient gas, as patterns such as swallowing failures via `try/catch` can cause "success-on-failure" behavior where the intended code did not actually execute.

Recommendation: Treat gas and `msg.value` on this receive path as attacker-controlled. Require the `target` contract to explicitly validate any expected `msg.value`, and structure target calls so they revert or otherwise fail clearly when insufficient gas prevents intended execution. Avoid failure-swallowing patterns that can make under-gassed calls look successful.

Sky: Acknowledged.

Cantina Managed: Acknowledged.

3.1.2 Calling `LZComposeReceiver.lzReceive` with `msg.value` results in locked native tokens

Severity: Informational

Context: `LZComposeReceiver.sol#L39`

Description: The `LZComposeReceiver` does not handle `msg.value` received in `_lzReceive`. If any caller (the Executor per misconfigured options, a user manually invoking `endpoint.lzReceive`) attaches native token (`msg.value`) to the `lzReceive` function call, the tokens would become locked in the contract without a withdrawal path.

Recommendation: Consider adding a `require(msg.value == 0)` or a sweep function to withdraw locked native tokens.

Sky: We acknowledge the risk of lost ether in case of misconfiguration or user error.

Cantina Managed: Acknowledged.